

Scenario: Autonomous vehicle**Group:**

Name	ID	Role
Gizem Kumrili	001313271	Group Leader
Abidur Rob	001381097-9	CyberSec Specialist
Elias D Chis	001402198	CyberSec Specialist
Tonny Andino Munoz	001393282	Researcher
Arafat Karim	001431226	Researcher
Paaralathan Yasotharan	001386934	Manager

Declarations:

Paaralathan: I have used AI for better formatting and for some paraphrasing assistance, I did all the analysis and calculations myself.

Gizem: I have used AI to research the formulas to do my arithmetic calculations. I have researched and found sources to reference my justifications on my own.

Elias: I have used AI tools to research and read about the different charts and presentation methods I could use to better express the attacker's methods.

Abid: I have used AI tools to assist me in formatting, and paraphrasing. All information was gathered via research.

Tonny: I used AI to sample the security policy templates to give me a better idea how to construct mine.

Activity 1: Asset Inventory (5 marks)

Asset	Type	Justification
Vehicle Control Unit (VCU) ★	Hardware /Software	This is the central component that controls critical vehicle functions.
GPS	Hardware	Important for real time location tracking and navigation to operate safely.
Mobile App	Software	To monitor, control, or update the vehicle remotely.
Car Operating System ★	Software	This is the core software that runs all in the car systems and applications.
Car Sensor	Hardware /Software	This collects environmental data necessary for autonomous decision making (e.g. Lidar, cameras).
Breaks / Acceleration	Hardware/Software	Important electromechanical systems for physical control of the vehicle's speed and movement.
Personal Data ★	Data	Highly sensitive data like journey logs and biometric authentication which is stored.
Neural Network	Data /Software	This is the core Machine Learning model that makes driving decisions and environmental awareness.

Vehicle Communication Link	Network	The network connection used for over the air updates and manufacturer communication to update systems from the cloud.
User Authentication	Data	Data used to verify the true driver's identity and permissions to give access.

Activity 2: Weighted Factor Asset Valuation (10 marks)

Assets	Safety Impact (0.5)	Operational Critically (0.3)	Data & Reputation Impact (0.2)	Score
Vehicle Control Unit (VCU)	100 x 0.5	100 x 0.3	100 x 0.2	100/100
Car Operating System	90 x 0.5	95 x 0.3	80 x 0.2	89.5/100
Neural Network	85 x 0.5	90 x 0.3	76 x 0.2	84.7/100
Vehicle Communication Link	80 x 0.5	85 x 0.3	97 x 0.2	84.9/100
Personal data	20 x 0.5	30 x 0.3	100 x 0.2	39/100

Activity 3: TVA Grid (Threat–Vulnerability–Asset) (10 marks)

Threats	Vulnerability	VCU	Car OS	Personal Data
Hacker sends malicious commands	Weak encryption / insecure firmware	T1 V1 A1		
Insider tampers with signals	Weak authentication / no monitoring	T2 V2 A1		
Malware through network connection	Open network ports / insecure interface	T3 V3 A1	T3 V1 A2	
Malware / ransomware	Bugs / unpatched software		T4 V1 A2	
Unauthorised remote access	Weak authentication / network flaws		T5 V2 A2	
Compromised software updates	Poor patching / no integrity checks		T6 V3 A2	
Data breach / hacking	Weak authentication / unencrypted storage			T7 V1 A3
Insider misuse	No access control / monitoring			T8 V2 A3
Data loss during backup	Misconfigured / unencrypted backups			T9 V3 A3
Priority of Controls		1	2	3

Vehicle Control Unit (VCU)

(C) Confidentiality	(I) Integrity	(A) Availability
Low there is no sensitive data	Critical since steering and or brakes is affected.	High is the vehicle cannot move would be disabled.
Low	Critical since it's not safe to operate.	High since the system would be shutdown.
Low	Critical because can cause wrong mechanical actions.	High since the full system cannot function.

Car Operating System

(C) Confidentiality	(I) Integrity	(A) Availability
Low since system data processes little personal info.	Commands may be altered, sensors could misread.	Automated features could fail, but manual control still exists.

Low, minimal sensitive data exposed.	Commands may be misread, which can lead to unsafe operation.	Loss of automated functions, manual control can be still used.
Low because updates don't usually consist of personal data.	OS or the sensors functions may be corrupted.	The vehicle could malfunction or even stop working.

Personal Data

(C) Confidentiality	(I) Integrity	(A) Availability
High, personal info like journey could be exposed.	Data could get changed, which could cause wrong reports.	Losing the data could make it harder to use for records or legal purposes.
High, sensitive info could be shared without consent.	Data could be used incorrectly, causing wrong analysis.	The car still works fine; the main impact is on reputation of the company.
Medium, some sensitive info could be lost.	Losing the data might cause mistakes in the reports.	Some operations or legal tasks could be affected, but the car still works.

Activity 4: Quantitative Risk Calculation (10 marks)

Asset 1: Vehicle Control Unit

Likelihood (0-1) = 0.8 Exhibits high exploitability via remote access interfaces and OTA update mechanisms.
ASP (0-1) (Attack Success Probability) = 0.9 The VCU governs steering, brakes, and acceleration. Its compromise results in physical damage or operational failure.
Probable loss (%) (Exposure Factor) = 0.6
Asset Value (£) = £120,000
Confidence (%) = 0.85 Supported by threat reports and recorded vulnerabilities in VCU protocols.
Risk (£) = Loss frequency = $0.8 \times 0.9 = 0.72$ --> Loss Magnitude = $£120,00 \times 0.6 = £72,000$ --> Loss frequency x Loss Magnitude = $0.72 \times £72,000 = £51,840$ --> Uncertainty = $1 - 0.85 = 0.15(15\%)$ --> $£51,840 \times 15\% = £7,776$ --> $£51,840 + £7,776 = £59,616$

Final interpretation: The impact of a successful attack would be operational failure or physical injury. Its exposure and criticality are represented by the high-risk rating. This calls for priority firmware hardening and secure OTA updates.

Asset 2: Vehicle Communication Link

Likelihood (0-1) = 0.7 V2X communication relies on wireless channels that are inherently open to attack vectors like spoofing and DOS.
ASP (0-1) (Attack Success Probability) = 0.8 The V2X communication link receives real time data about hazards. An attack on this system such as receiving fake basic safety messages.
Probable loss (%) (Exposure Factor) = 0.6
Asset Value (£) = £120,000
Confidence (%) = 0.85 Supported by the large amounts of public research specifically targeting V2X.

Risk (£) = Loss frequency = $0.7 \times 0.8 = 0.56$ --> **Loss Magnitude = $\text{£}120,000 \times 0.6 = \text{£}72,000$ --> **Loss frequency x Loss Magnitude** = $0.56 \times \text{£}72,000 = \text{£}40,320$**
Uncertainty = $1 - 0.85 = 0.15(15\%)$ --> $\text{£}40,320 \times 15\% = \text{£}6,048$ --> $\text{£}40,320 + \text{£}6,048 = \text{£}46,368$

Final Interpretation: Vehicle communication link is a critical system for safe autonomous operation, transmitting essential data between vehicle and its environment. We should prioritise investing in securing V2X communication channels.

Activity 5: CVSS-lite Vulnerability Scoring (10 marks)

Asset: VCU Vulnerability: Buffer Overflow in CAN Message Parsing (Remote Code Execution Potential)

Metric	Score
Exploitability (0-10)	9.6 - High because buffer overflows are highly predictable, highly exploitable, and there is no native authentication on the CAN bus.
Impact (0-10)	9.8 - Near-maximum because the attack has system-level effects on safety-critical functions and can also inflict physical harm.
ScopeX	1.5 - The exploitation can propagate malicious commands to a wide range of ECUs across the CAN network.
Vulnerability score	Raw: $(9.6 + 9.8) \times 1.5 = 29.1$ / Normalised: $29.1/30 = 9.7$ Displays critical severity; high likelihood of exploit with high severity cross-system impact.

Mapping to Asset Sensitivity Profile (ASP) Delta

Parameter	Baseline	Adjusted
ASP (Asset Sensitivity Profile) - VCU remains highly critical; ASP has asset value captured.	0.9	0.9
Exposure Factor (Probable Loss) - Buffer overflow allows for potential remote compromise and full system crash; risk of	0.6	0.85

Recomputed risk

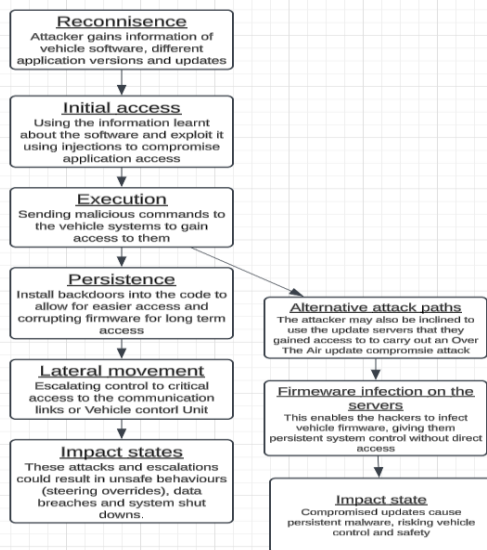
Numeric Risk = Likelihood of exploitation $\times$ Operational impact (ASP) $\times$ Exposure Factor $\times$ Asset Value
 $(0.8 \times 0.9 = 0.72 \text{ --> } 0.72 \times 0.85 = 0.612 \text{ --> } 0.612 \times \text{£}120,000 = \text{£}73,440)$

Activity 6: Attack Path (MITRE ATLAS style) (10 marks)

Stage	Technique	Observable indication	Detection / Control
Reconnaissance	The attacker looks for information about the vehicles software and online systems.	Multiple failed login attempts, unusual data requests.	Require authenticated access.
Initial Access	Via compromised credentials, phishing or mobile app access.	logins from abnormal locations.	Enforce two factor authentication.
Execution	Attacker sends new inputs/commands that confuses the VCU's decision making process.	Randomly executed car commands not from the driver.	Verify all commands are from the driver, ignore commands from out of range.

Persistence	Via corrupting the cars boot firmware, by installing malicious firmware.	Slightly longer boot times in car software.	Only allow official updates from a single server.
Lateral Movement	The attacker transitions into the VCU and brake commands.	Service requests targeting VCU	Strong network segregation from physical components.
Impact	Attacker triggers commands, such as unexpected braking.	Sensors beeping when driving.	Ensure the vehicle can enter a safe mode if the data looks wrong.

Activity 7: Attack Graph Design (10 marks)



The Directed Acyclic Graph (DAG) was chosen because it shows the step-by-step process of a crime without reversing direction. From the start to the finish, it helps analysts in tracking down every connection. Its structure simplifies analysis, as well as finding the weaknesses.

Activity 8: Defence & Controls Map (10 marks)

Attack step	Technical control	Organizational control	Estimate effective ness (%)	Trade-off notes
Reconnaissance	Networking monitoring systems to flag large data requests made by users.	Access management with less privileges to prevent the escalation, developer training to prevent data leaks.	80%	Continuous data monitoring can be costly.
Initial access	Multi-factor authentication and role-based log in methods for all users and systems.	Enforcement of credential management and employee training against phishing.	85%	Some users have inconvenience with the MFA.
Execution	Secure cryptographic commands between all the control units.	Review the software integrity regularly and emergency response drills for engineers.	90%	There is a high cost of integration for this.
Persistence	Secure the firmware signing to prevent faulty software.	Patch management alongside third-party	88%	Maintenance costs could be high.

		updates on verification and procedures.		
Lateral movement	Segmenting the network to isolate vehicle control units.	Defined policy for incident escalation and internal network access audits.	82%	Network redesign costs would be high.
Impact	Emergency safe mode triggers.	Incident response plan with defined measures on how to contain the incident.	90%	Requires continuous maintenance costs.

Activity 9: Short Incident Response Plan (10 marks)

Scenario: Vehicle Control Unit (VCU) Compromise.

Objective: Immediate containment of compromised features and rapid recovery.

(a) Immediate containment

- Once an incident is identified, the priority is to isolate the effected vehicle, by disabling cloud access and connectivity until the issue is resolved.
- After the vehicle is isolated, the owner should be notified, and all software-based systems, such as self-driving should be temporarily disabled.
- Once these two steps have been fulfilled, the priority shifts to blocking all attacker paths/routes by suspending compromised user accounts.

(b) Evidence to Preserve

- Network traffic: All inbound and outbound traffic, requests, telematics and communication over the last week.
- Remote commands: All remote commands that have been sent to the vehicle.
- VCU firmware: current logs for firmware and its last recorded update.

(c) Stakeholder Notification list & timelines

Stakeholder	Reason	Timeline
Vehicle Networking Team	To contain and recover as much data as possible.	Within the same hour of incident.
Vehicle Engineering Team	To understand the vulnerability of the VCU, how it was exploited and how to prevent it in the future.	Within an hour of the incident being contained.
Affected Customer	Safety alert, notifying the customer if any of their data was stolen or if they are still at risk.	Within the same hour the company is notified.
Legal Authorities	If there are data theft or other malicious intents, it is a legal requirement to inform relevant authorities like police or ICO.	If necessary, Within 48 hours.

(a) Top 3 remediation steps + rollback timeline

- Fix / resend VCU firmware to replace old, infected copy.
- Resend credentials to the customer, such as a new app token, accounts etc.
- Implement new security measures to ensure this exploit is no longer available.

Activity 10: Quick Policy (5 marks)

Purpose and scope: Defines the security requirements and responsibilities for protecting the VCU against buffer overflow vulnerabilities in the controller area network message parsing process. It applies to all VCU software components, developers and integrators.

Policy requirements:

- All VCU firmware must implement strict input validation to verify the size and structure of every incoming CAN message before it is processed.
- Developers must use secure coding practices, including safe memory's operations, statics buffer allocation with defined limits and compiler protections.
- CAN message handlers are required to be fuzz tested using randomised input data to confirm that no overflow conditions can be triggered.

Enforcement:

Compliance to this policy is mandatory. Failing to comply may result in suspension of software deployment, mandatory revalidation or escalation to senior engineering management. Regular internal audits will verify that these safeguards are properly implemented and maintained through the VCU development lifecycle.

Activity 11: Executive One-page Brief (5 marks)

Top Risk:

The vehicle's steering, braking, and acceleration is controlled by the VCU. If a successful attack results in complete control loss, causing the manufacturer reputation to be damaged or even the passenger's life to be at risk.

Impact Summary:

1. *Safety Impact:* Extremely high since a loss of steering or braking control can cause accidents or even worse fatalities.
2. *Operational Impact:* High because there is no safe way for the vehicle to run either manually or automatically, which leads to total failure.
3. *Data & Reputation Impact:* High because brand trust and confidence in autonomous cars would be damaged if such an incidence became public news.

Residual Risk:

Evaluation	Value
Inherent Risk Score	100/100
Residual Risk Score	45/100
Residual Risk Band	Medium

Recommended Controls:

1. *Secure Firmware Verification:* To stop malicious code insertion, all VCU software must use updates that are securely signed and verified using encryption.
2. *Network classification and Encryption:* To prevent remote commands and spoofing, we can separate the VCU from external communication components.
3. *Real-time monitoring and patch management:* This allows us to address weaknesses and continuous threat detection and allow us to update the system.

Possible Hindrances:

1. *High Implementation Cost*: A large investment is needed for firmware signatures, secure hardware, and monitoring equipment.
2. *System Downtime & Testing Delays*: To avoid security risks, every firmware update must go through extensive testing before it is released.
3. *Third-Party Dependencies*: If external suppliers don't meet with security standards, installation may be delayed, or risks may be introduced.

Activity 12: Reflective Learning Statement (5 marks)

Paaralathan: I gained knowledge on how to evaluate cybersecurity threats using weighted scoring methods. Better understanding of how different components contribute to the safety and security on autonomous cars, I learned what would happen if these components were attacked. If I had to redo this project, I would improve my visual representation of the data and add more numbers to compare assets that way we can compare and come to a better conclusion on what component has the biggest safety risk. I have used AI for better formatting and for some paraphrasing assistance, I did all the analysis and calculations myself.

Arafat: My research on weighted factor asset and quantitative risk helped me understand how you would assign monetary values to risks and determine what the assets are worth. I learned quantitative risk uses numerical data to measure the impact of risks. I also now understand that weighted factor asset valuation is the process of figuring out the financial value of an asset by considering factors and how important they are. Doing this project again, I would breakdown asset components to allow for more precise valuation. I would also incorporate sensitivity analysis to understand how the values of different variables impact the risk assessment.

Gizem: I educated myself on how to compute risk, produce an in-depth, informative CVSS-lite sheet and improve my research skills immensely to find justifications on my decisions and improve my understanding on vulnerabilities. Two things I would do differently now is trying to use more technical phrasing to enhance my academic knowledge in my work and compare multiple quantitative risk models to gain more certainty rather than relying on one source of a risk model. I have researched and found sources to reference my justifications on my own.

Elias: I discovered that by representing attacker actions and system states as nodes, Directed Acyclic Graphs (DAGs) characterise cybersecurity attack routes and demonstrate progression. By preventing loops, DAGs make sequences more logical and easier to understand. Including alternative attack routes adds realism and helps identify where security can improve to mitigate future risks. I also explored lots of trade-offs in cybersecurity, such as increased latency from security measures. While my tasks focused on linear paths, using visual tools like DAGs earlier could have enhanced my analysis. I used AI tools to research chart types and presentation methods for expressing attacker methods effectively.

Abid: I learnt several key concepts about electric vehicles, their security and how they operate. I learnt what a Vehicle Control Unit (VCU) is, how telematics and OTA update's

function, and how to model attacks using a MITRE ATLAS style attack path. I've also learnt how to describe network commands, identify signs of cloud scanning, and write a realistic incident response plan with a clear rollback timeline. My communication of technical ideas became clearer and more professional whilst tackling this project. Nevertheless, I could have improved by linking each activity more effectively and provided deeper risk analysis during my incident report. I utilised AI to create structures, and for paraphrasing assistance.

Tonny: I got valuable insight on how to approach vulnerability analysis both technical and policy perspective. By researching a controller area network message parsing overflow vulnerability for a VCU asset. Using the CVSS lite framework it helped quantify risk and communicate its severity more effectively. I also wrote a short security policy which portrayed the importance of defining a clear scope. If I could have improved, I would have spent more time validating the technical sources which will help me with a deeper understanding. I used AI to sample the security policy templates to give me a better idea how to construct mine.

References:

Paaralathan

1	LevelBlue. (2023) The top 8 Cybersecurity threats facing the automotive industry.
2	Vicone. (n.d.) Pioneering the Future of Automotive Cybersecurity With Unparalleled Automotive Threat Intelligence.
3	Splunk. (n.d.) What's The CIA Triad? Confidentiality, Integrity, & Availability.
4	Embitel. (2025) Integrated VCU in Contemporary Electric Vehicles.

Gizem

1	Lu, W. (n.d.). AUTONOMOUS VEHICLE AND RISK ASSESSMENT.
2	MITRE (2024). MITRE ATT&CK®.
3	National Highway Traffic Safety Administration (2019). NHTSA.

Tonny

1	CVSS v4.0 specification document. FIRST. (n.d.).
2	CVSS. prostep ivip: Common Vulnerability Scoring System (CVSS). (n.d.).
3	A qualitative security risk assessment - sciencedirect. (n.d.).
4	Division of Risk Management for autonomous vehicles. (n.d.-b).

Arafat

1	Al-Qassab, M., Al-Kahtani, M., Al-Ahdal, M., Al-Ghamdi, A. and Al-Shehri, W. (2024) ADVERSARIAL ATTACKS ON NEURAL NETWORKS.
2	Bar-Gill, I. (2018) The Promise And Challenges Of V2V Communication.
3	SecureITworld (2023) Understanding V2X Cybersecurity
4	Ma, X., Li, C. and Wu, Y. (2023) Integrated Sensing and Communication for Joint GPS Spoofing and Jamming Detection in Vehicular V2X Networks.

Elias

1	Puppygraph.com. (2025). Visualizing Cyber Threats: Introduction to a Attack Graphs.
2	Koon, J. (2022). Cybersecurity Risks Of Automotive OTA.
3	Darktrace.com. (2024). Darktrace.
4	Venables, M. (2023). Cyber security solution for automotive ECUs.

Abid

1	Exro Technologies Inc. (2025) The Brain Behind EVs: The Role of a VCU.
2	Ellis, D. (2025) '6 Phases in an Incident Response Plan', SecurityMetrics Blog.
3	National Cyber Security Centre. (n.d.) Cyber incident response processes.